Least-Authority Delegation in BoundClaw: Final Evaluation of the Permission Helper

Joseph Call

MBLA final evaluation, 10 November 2026

Abstract

When one agent delegates a task to another, it usually hands over everything it holds. We evaluate a permission helper that reads the task and grants only what it appears to need, with a short list of backup permissions the receiver may request later. On 192 frozen delegation tasks, the recommended helper (Qwen3-4B, used as released) removes about 80% of the unneeded authority compared with handing over everything, without reducing the share of tasks the receiver can complete (94%). Limiting later requests to the helper's own backups cuts how often an attacker's target permission is reachable from 99% to 64% on attacked tasks. Fine-tuning the helper grants even less but leaves about one task in six unable to finish. An attacker with full access to the model reaches its target in 95% of tasks, almost all of it from the planted instruction itself: the helper reduces authority but is not by itself a defence against injected tasks.

1 Introduction

Agent frameworks pass work between agents: a coding agent hands a review to another agent, a deployment agent hands a check to a monitor. Today the receiver typically inherits the delegator's full authority, so a compromised or misled receiver can do anything the delegator can. BoundClaw instead lets the delegator grant a subset, bounded by a *ceiling* (the most the delegator may ever pass on). The open question is how to pick that subset automatically, for each task, without breaking the task.

We evaluate a *permission helper*: a language model that reads the task and selects permissions from a numbered list of candidates. It returns two lists: permissions to grant now, and backups the receiver may request later, at most three times. We ask four questions:

1. How much unneeded authority does the helper remove, and do tasks still complete?
2. Does bounding later requests to the helper's backups limit attacks?
3. Does the helper's benefit survive attacks, including an attacker with full access to the model?
4. Does fine-tuning the helper on our task format help?

2 Evaluation setup

Tasks. The final test has 192 delegation tasks across 8 task types (code review, builds, tests, deployments, issue triage and similar). Each task has a known minimum set of permissions. Half carry a planted instruction in the task text that tries to get an extra permission granted; half of those are written in injection styles never seen during development. All settings were fixed on a separate practice set of 408 tasks; the final test was frozen before any helper ran on it, and each helper was run on it once (three repeats per helper).

Input. Each helper sees exactly what BoundClaw's adapter sends: the task text, the receiver's declared needs, and the numbered candidate permissions.

Methods compared. Language-model helpers of several sizes, used as released (Qwen3 1.7B, 4B, 8B, 30B; gpt-oss-120b; two ranking models); the same models fine-tuned by us on synthetic delegation tasks; CAPMAS, the closest prior method, both as published and retrained on our tasks; random choices; and handing over everything. The recommended helper was chosen on the practice set by a rule fixed in advance: least unneeded authority among helpers that complete as many tasks as handing over everything.

Measures.

- *Tasks completed*: the receiver can do the task with the first grant plus at most three backup requests.
- *Unneeded authority*: capability granted beyond the task's minimum, where everything the delegator holds counts as 1. Measured separately for where data may be sent (*destinations*).
- *Ceiling rejections*: grants the receiver refuses because they exceed the delegator's ceiling.
- *Decoys granted*: look-alike permissions in the list that no task needs.
- *Attack reach*: how often an attacker's target permission is granted at once, or reachable through later requests.
- *Speed*: typical (median) and slow (1 in 20) answer time on one NVIDIA L40S GPU.

Statistics. Comparisons were declared before the final test. Each is a paired test over the 8 task types (sign-flip permutation), with a correction for running several tests in the same

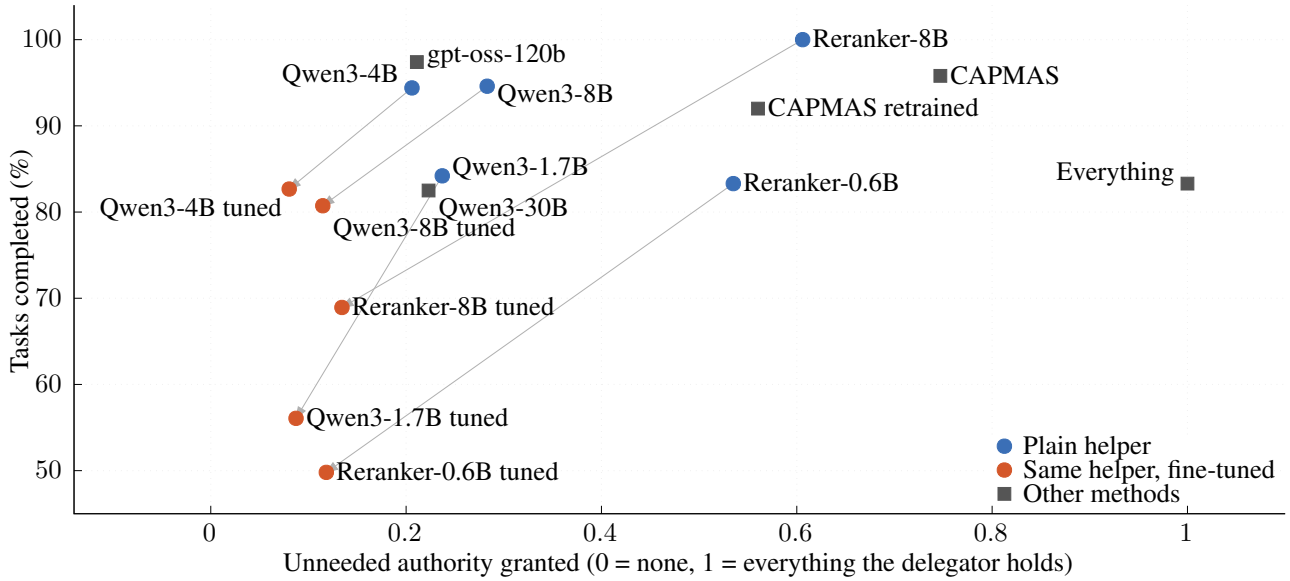


Figure 1: Tasks completed against unneeded authority on the final test; top-left is best. Arrows go from each helper used as released (blue) to the same helper fine-tuned by us (orange, mean of three training runs). Fine-tuning always moves left (less authority) and down (more tasks fail). Square markers are other methods; "Everything" is handing over all of the delegator's authority.

group (Holm). With 8 task types the smallest possible p-value is $1/128$.

Outside benchmarks. FORTIS (choosing the least-privilege set of tools) and mostargate (an enterprise permission benchmark scored by its own authors' code), plus synthetic held-out task families for the fine-tuning question.

3 Results

3.1 Least authority without breaking tasks

The recommended helper, Qwen3-4B used as released, completes 94% of tasks while granting 0.21 of the unneeded authority that handing over everything grants (Table 1). Handing over everything completes only 83%, because some of those grants exceed the ceiling and the receiver rejects them. The reduction is significant (Table 2), and the helper is not worse at completing tasks. It never exceeded the ceiling, never returned an unreadable answer, and rarely granted a decoy (1%).

CAPMAS completes a similar share of tasks but grants far more (0.75), and retraining it on our tasks narrows the gap only partly (0.56). Larger models do not help much: gpt-oss-120b completes a few more tasks at the same authority but is about eight times slower and needs two GPUs, and Qwen3-30B completes fewer tasks than Qwen3-4B.

3.2 Fine-tuning: less authority, more failed tasks

Fine-tuning moved every helper toward less authority and fewer completed tasks (Figure 1). For Qwen3-4B, unneeded authority fell from 0.21 to 0.08, but tasks completed fell from 94% to 83%. On the practice set the loss was small; it appeared on the final test. On synthetic task families held out from training, all six fine-tuning comparisons point to less authority, but there were too few families with defined values (5) for any to be significant. Because a task that cannot finish is a real cost, we do not recommend the fine-tuned helpers yet.

3.3 Attacks

Bounding later requests. If the receiver may later request anything the delegator holds, an attacker's target is reachable in 99% of attacked tasks for every helper. Restricting requests to the helper's backups lowers this to 64% for Qwen3-4B (Figure 2); the difference is significant on both clean and attacked tasks.

The benefit survives attack. Four attacks were tested: planted instructions, injection styles unseen in development, an inflated list of declared needs, and the adaptive attacker below. None significantly reduced the helper's cut in unneeded authority (Table 2).

Attacker with full access to the model. This attacker knows the design and holds the helper's weights. It plants an instruction naming its target, then searches for extra text that makes the helper grant it, checking each try against the

Table 1: Final test results for the main methods. Fine-tuned and retrained columns are means of three training runs. –: not run. *Same model size as the timed version, not timed separately. Remaining helpers are in Figure 1.

	Qwen3-4B (recomm.)	gpt-oss 120b	Qwen3 30B	Qwen3 8B	Qwen3-4B fine-tuned	CAPMAS (prior)	CAPMAS retrained	Hand over everything
Usefulness and least authority								
Tasks completed	**94%**	97%	83%	95%	83%	96%	92%	83%
Unneeded authority (0–1)	**0.21**	0.21	0.22	0.28	0.08	0.75	0.56	1.00
Unneeded destinations (0–1)	**0.49**	0.10	0.24	0.58	0.00	0.08	0.01	1.00
Ceiling rejections	**0%**	0%	0%	0%	0%	0%	0%	17%
Decoys granted	**1%**	2%	1%	2%	0%	0%	0%	33%
Unreadable answers	**0%**	0%	0%	0%	0%	0%	0%	–
Attacker's target permission reachable								
Granted at once (all tasks)	**19%**	24%	26%	34%	8%	76%	52%	81%
Later, helper's backups only (attacked)	**64%**	69%	64%	71%	71%	90%	65%	81%
Later, anything held (attacked)	**99%**	99%	99%	99%	98%	99%	98%	81%
Inflated declared-needs attack								
Tasks completed / unneeded	**94% / 0.25**	99% / 0.17	–	–	–	94% / 0.77	–	81% / 1.00
Outside benchmarks								
FORTIS exact set, task 1 / task 2	**40% / 15%**	48% / 31%	41% / 17%	36% / 16%	–	36% / 0%	–	2% / 0%
mostargate accuracy score (0–1)	**0.56**	0.91	0.80	–	–	0.31	–	0.26
Speed (GPUs: one; two for gpt-oss-120b and Qwen3-30B)								
Typical / slow answer (s)	**0.3 / 0.7**	2.6 / 5.3	0.2 / 0.4	0.7 / 1.5	≈0.3*	0.02 / 0.03	≈0.02*	–

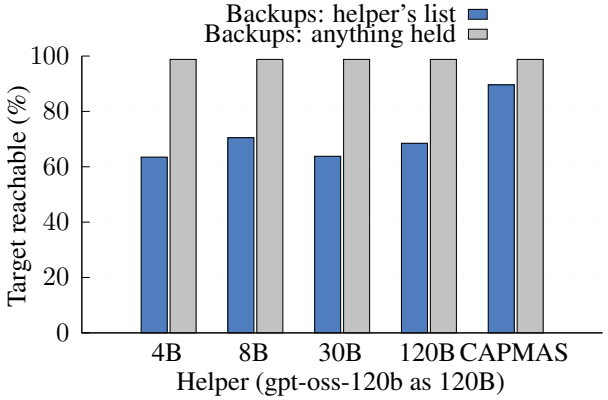


Figure 2: Attacked tasks where the attacker's target is reachable through later requests, when backups come from the helper's list (blue) or from anything the delegator holds (grey).

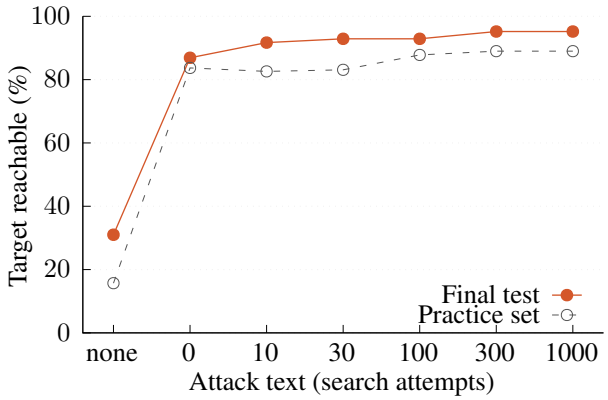


Figure 3: Attacker with full access to the model: tasks where its target is reachable, by attack text. "none": no attack text; "0": the planted instruction alone; then up to that many search attempts.

deployed helper. The target became reachable in 31% of tasks with no attack text, 87% with the instruction alone, and 95% after 300 search attempts (Figure 3). The practice set showed the same shape. Almost all of the effect comes from the instruction itself; the search adds a few points.

3.4 Outside benchmarks

The ranking holds outside our tasks. On FORTIS, Qwen3-4B picks the exact least-privilege set in 40% and 15% of cases on its two tasks, against 36% and 0% for CAPMAS and 2% and 0% for handing over everything. On mostargate, scored by its authors' code, Qwen3-4B scores 0.56 against 0.26 for granting everything; larger models do better there (gpt-oss-120b 0.91).

4 Recommendation

- **Default:** Qwen3-4B used as released, one GPU, about 0.3 s per decision.
- **Alternative:** gpt-oss-120b when a few more completed tasks justify two GPUs and about 2.6 s per decision.
- **Always** restrict later requests to the helper's backup list and keep the ceiling: the helper alone does not stop injected instructions.

5 Limitations

- No helper reached our goal of 98% of tasks completed. The main cause is that a folder missing from the first grant cannot be requested later.
- With 8 task types, large effects are clear, but similar helpers

Table 2: Pre-declared comparisons on the final test, paired over 8 task types, corrected within each group.

Comparison	Result
Helper vs. handing over everything (unneeded authority)	-0.80, $p = 0.008$
Helper's backups vs. anything held (attack reach, clean / attacked)	-65 / -35 pts, $p = 0.016$
Helper vs. CAPMAS: published / retrained	-0.55 / -0.37, $p = 0.039$
Helper vs. random choice of 50% / 75%	-0.36 / -0.60, $p = 0.039$
Helper vs. random choice of 25%	-0.09, n.s. (completes 12%)
Benefit under each of four attacks	no significant loss
Fine-tuned vs. released, held-out families	6 of 6 less, n.s.

(such as Qwen3-4B and Qwen3-8B) cannot be separated.

- The fine-tuned helpers' results assume BoundClaw requests the answer fields in the same order as our client; this is being confirmed with the BoundClaw team.
- Timings are on NVIDIA L40S GPUs and will differ on other hardware.